

REMEDIATION ENABLEMENT FRAMEWORK

Risk Acceptance for Security Findings

Purpose

Define a platform-neutral reference process for explaining, recording, reviewing and reassessing a client decision to accept an unresolved security finding without transferring business-risk ownership to the assessor.

Author: Daniel Jones

Version: 1.0

Status: Portfolio-ready reference process specification

Design position: Platform-neutral, client-owned risk decision, automation optional

Contents

1	Executive Summary
2	Purpose, Scope and Applicability
3	Working Definitions
4	Core Principle and Responsibility Boundary
5	When Risk Acceptance May Be Considered
6	Minimum Acceptance Record
7	Platform-Neutral Reference Workflow
8	Review and Reassessment
9	Consultant Interaction and Escalation
10	Optional Automation and AI Assistance
11	Implementation Model
12	Risks and Controls
13	Validation Criteria
14	Conclusion
Appendix A	Example Risk Acceptance Record

1. Executive Summary

Risk acceptance is a legitimate treatment decision for some security findings, but it is not the same as remediation or technical closure. A vulnerability may remain present even when an organisation has consciously decided to tolerate the associated residual risk.

This framework provides a consistent and reviewable process for recording that decision. It deliberately separates the responsibilities of the security assessor from those of the client-side risk owner. The assessor explains the finding, technical evidence, security impact and approved remediation advice. The client determines whether the remaining risk is acceptable within its own operational, financial, regulatory and strategic context.

The framework is platform-neutral. It can be adapted to a penetration-testing workflow, vulnerability-management platform, ticketing system, governance process or other finding-management environment. It does not depend on a particular portal, vendor or service-delivery model.

Core principle

Risk acceptance records a business decision to tolerate an unresolved security risk. It does not prove remediation, change the original technical severity, or remove the vulnerability from view.

2. Purpose, Scope and Applicability

The framework is intended for security findings produced through authorised assessments and reviews. Its purpose is to improve the quality, transparency and lifecycle management of risk-acceptance decisions without turning the assessment provider into the owner of the client's business risk.

It is designed to support organisations that need a lightweight, auditable process rather than a full enterprise risk-management platform. The framework may be embedded into an existing system or used as a standalone documented process.

2.1 In scope

- Recording why a finding is being accepted rather than remediated immediately.
- Identifying an appropriate client-side risk owner.
- Documenting compensating controls, dependencies and planned remediation where relevant.
- Setting review dates and reassessment triggers.
- Keeping accepted-but-unresolved findings visible and distinguishable from remediated findings.
- Providing technical clarification from the assessor where required.

2.2 Out of scope

- Deciding the client's risk appetite or approving acceptance on the client's behalf.
- Providing a legal, regulatory or compliance guarantee.
- Changing the finding severity, technical conclusion or evidence.
- Treating acceptance as proof that the underlying weakness has been fixed.
- Replacing a client's wider governance, enterprise-risk or change-management processes.

3. Working Definitions

Term	Working meaning
Remediation	A change intended to remove or resolve the identified vulnerability or weakness.
Mitigation	A control or change that reduces the likelihood or impact of exploitation without necessarily removing the underlying weakness.
Compensating control	An alternative control that helps reduce exposure where the preferred remediation is not currently possible or practical.
Risk acceptance	A conscious business decision to tolerate the remaining risk associated with an unresolved finding for a defined reason and, ideally, a defined period.
Risk owner	The client-side person or role with appropriate authority to own and accept the business risk. This is not automatically the penetration tester or assessment consultant.
Review date	The date on which the acceptance decision should be reconsidered to confirm that its assumptions, controls and business context still apply.
Residual risk	The risk that remains after existing controls, mitigations or compensating controls are taken into account.

4. Core Principle and Responsibility Boundary

A technically informed assessor can explain a vulnerability and the consequences of leaving it unresolved, but may not possess the client's risk appetite, financial position, regulatory context, service criticality or strategic plans. The framework therefore separates technical advisory responsibility from business-risk ownership.

Security assessor / consultancy	Client / risk owner
Explain the finding and technical evidence.	Decide whether the residual risk is acceptable.
Explain the known technical and security impact.	Nominate or confirm an authorised risk owner.
Provide approved remediation advice.	Provide the business justification for acceptance.
Explain that acceptance leaves residual risk.	Assess operational, financial and strategic consequences.
Clarify how later remediation would be verified.	Confirm compensating controls and business dependencies.
Flag information that is unknown or client-owned.	Set the review period and approve continued acceptance.

Responsibility boundary

The assessor informs the decision; the client owns the decision. If a question requires organisation-wide risk judgement beyond the assessment scope, it should be escalated to an appropriately authorised client or advisory role.

5. When Risk Acceptance May Be Considered

The framework does not prescribe when a client should accept risk. It identifies common circumstances that may justify structured consideration while keeping the decision with the client.

Temporary technical constraint

The preferred remediation cannot be applied immediately because of compatibility, vendor or implementation constraints.

Planned replacement

The affected system or service is already scheduled for retirement, migration or replacement and the client intends to manage the exposure until that event.

Operational dependency

Immediate remediation would create a material service or operational impact and the client chooses an interim risk-treatment approach.

Compensating controls

Other controls materially reduce exposure while the underlying weakness remains present.

Business decision

An authorised client-side risk owner determines that the residual risk falls within the organisation's tolerance.

Important

None of these circumstances automatically make acceptance appropriate. They are prompts for structured consideration, not rules for an assessor to apply on a client's behalf.

6. Minimum Acceptance Record

A useful acceptance record should capture enough information to make the decision understandable and reviewable without becoming an enterprise risk register in its own right.

Field	Purpose	Suggested requirement	Example
Reason for acceptance	Why remediation is not currently being completed.	Required	Legacy platform scheduled for replacement.
Risk owner	Client-side role accountable for the decision.	Required / strongly recommended	Head of IT
Compensating controls	Controls that may reduce exposure while the weakness remains.	Optional but prompted	Management interface restricted to trusted source ranges.
Planned remediation / replacement	Whether a longer-term resolution is already planned.	Optional	Replacement project approved.
Acceptance date	When the decision was made.	Required / system recorded	19 Aug 2026
Review date	When the decision should be reconsidered.	Strongly recommended	19 Feb 2027
Supporting notes / evidence	Relevant context such as a change reference, architecture note or risk-register reference.	Optional	Change ticket or governance record.

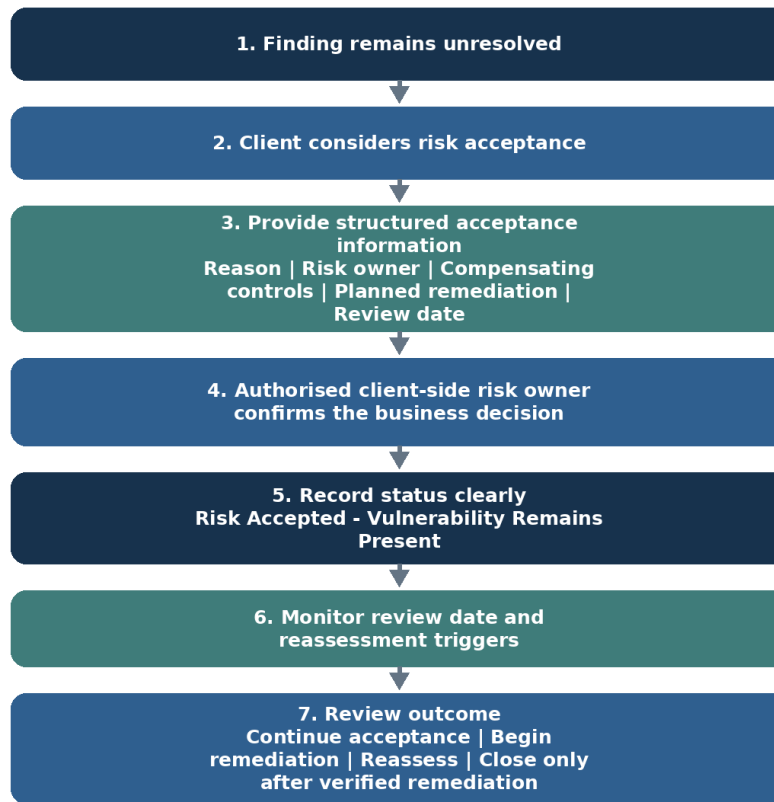
6.1 Status language

The finding state should remain explicit that the vulnerability is unresolved. A label such as “Risk Accepted - Vulnerability Remains Present” is preferable to a generic “Closed” or “Accepted” state that could be mistaken for technical remediation.

7. Platform-Neutral Reference Workflow

The workflow below is a reference process rather than a prescribed user interface. It can be implemented through a portal, ticketing system, governance platform, spreadsheet-controlled process or other finding-management mechanism.

Platform-Neutral Risk Acceptance Reference Workflow



7.1 Reference process steps

1. The security finding remains visible as technically unresolved.
2. The client indicates that risk acceptance is being considered instead of immediate remediation.
3. The workflow explains that acceptance is a business decision and does not remediate the vulnerability.
4. The client records the reason, authorised risk owner, compensating controls, planned remediation and review date as applicable.
5. An authorised client-side risk owner confirms the acceptance decision.
6. The finding lifecycle records the acceptance without changing the original severity or technical conclusion.
7. The acceptance is reviewed at the agreed date or earlier if a reassessment trigger occurs.

8. The client may continue acceptance, begin remediation, reassess the risk, or move to technical verification once remediation has been implemented.

7.2 Example client-facing guidance

Accepting this risk

Accepting a finding does not resolve the underlying vulnerability. It records a business decision to tolerate the remaining exposure rather than remediate it at this time. Record why remediation is not currently being completed, who owns the decision, any controls reducing the exposure, and when the decision should be reviewed again.

8. Review and Reassessment

Risk acceptance should not become permanent by accident. A review date provides a baseline control, but changes in the environment or threat context can invalidate the assumptions that supported the original decision.

8.1 Typical reassessment triggers

- The agreed review or expiry date is reached.
- The affected asset becomes more exposed or more business-critical.
- A relevant exploit, threat or attack path materially changes the likelihood of exploitation.
- A compensating control is removed, weakened or fails.
- The affected system is materially changed, migrated or replaced.
- A related assessment identifies a new or connected attack path.
- Regulatory, contractual or customer requirements change.

8.2 Review outcomes

Outcome	Meaning
Continue acceptance	The client confirms that the rationale and controls remain valid and sets a new review date where appropriate.
Begin remediation	The client moves the finding back into active remediation planning.
Reassess decision	New information means the original risk decision requires wider review.
Technical verification	Remediation has been implemented and the finding proceeds to the applicable validation or retest process.
Superseded / changed condition	The environment has changed enough that the original finding may need to be reconsidered through the normal assessment process.

9. Consultant Interaction and Escalation

Routine risk acceptance should not require the assessor to approve the client's business decision. Consultant involvement should remain focused on technical clarification: what the finding means, the known technical impact, the approved remediation advice, and how later remediation would be verified.

A risk-acceptance record may be visible to consultants during later debriefs, retests or related assessments, but visibility does not transfer ownership. Where a client asks whether a compensating control makes the business risk acceptable, the question may require escalation to an appropriately experienced security advisory, risk-management, compliance or client governance role.

Escalation rule

Escalate when the requested judgement depends materially on business criticality, risk appetite, finance, regulation, strategy or organisational priorities that are outside the assessor's authorised scope.

10. Optional Automation and AI Assistance

The framework must be usable without AI. Automation or AI may be introduced later as an assistance layer where it improves consistency or reduces administrative effort without taking over the risk decision.

Automation / AI may assist with	Example use	Boundary
Explain the specific finding in plain language	Summarise the known exposure using approved finding content.	Must remain traceable to the original finding and must not change the technical conclusion.
Prompt for missing information	Highlight that a review date, risk owner or reason has not been supplied.	Prompt only; do not infer or mandate a business decision.
Suggest categories of compensating controls to document	Ask whether access restrictions, monitoring or segmentation are relevant.	Must not invent controls or claim that they are effective.
Improve clarity of client-entered text	Rewrite a short justification more clearly while preserving meaning.	Client or authorised owner must approve the final statement.
Flag stale acceptance	Highlight that a review date has passed.	No automatic renewal, closure or risk approval.

Automation or AI must not:

- Decide that a client should accept the risk.
- Determine the client's risk appetite.
- Approve acceptance on behalf of the client.
- Invent compensating controls, business justification or operational facts.
- Change the technical severity or conclusion of the original finding.
- Claim that the vulnerability is remediated or closed.
- Provide legal, regulatory or compliance assurances.

11. Implementation Model

Implementation should begin with the simplest workflow that creates useful, reviewable records. The framework does not require sophisticated automation or a major platform redesign.

Phase	Reference implementation
Phase 1 - Guidance and structured fields	Introduce plain-English guidance and the minimum acceptance record. No automated risk decision-making.
Phase 2 - Review lifecycle	Add review dates, expiry indicators and visibility of accepted-but-unresolved findings.
Phase 3 - Contextual assistance	Optionally use approved automation or AI to tailor explanations and identify incomplete records.
Phase 4 - Wider remediation integration	Connect acceptance state and review information into broader remediation dashboards, reporting or cross-assessment workflows if required.

11.1 Adaptation points

- Which fields are mandatory, optional or system-generated.
- Which client roles are authorised to confirm risk acceptance.
- Whether review dates are mandatory, recommended or configurable.
- How accepted-but-unresolved findings are represented in reports and dashboards.
- How expired or overdue acceptances are surfaced.
- Whether the workflow integrates with a client risk register or remains within finding management.
- What legal, contractual, privacy or governance review is required before deployment.
- Whether automation or AI is justified by measurable benefit.

12. Risks and Controls

Risk	Why it matters	Control
Assessor becomes de facto risk owner	Clients may look to the assessor to approve acceptance.	Make client ownership explicit; assessors explain technical risk but do not approve the business decision.
Acceptance becomes permanent	A finding may remain accepted indefinitely and disappear from attention.	Use review dates, expiry indicators and reassessment triggers.
False sense of closure	Accepted status may be interpreted as resolved.	Use explicit status language stating that the vulnerability remains present.
Poor justification	Minimal free text may make the record meaningless.	Use structured prompts and examples rather than a single unrestricted text field.
Compensating controls overstated	A control may be recorded without evidence that it materially reduces exposure.	Treat controls as client-supplied context unless independently assessed; do not imply assurance.
Automation oversteps	Automation may imply that acceptance is appropriate.	Restrict automation to explanation, prompting, formatting and completeness assistance.
Sensitive information captured unnecessarily	Acceptance notes may contain information not required for the decision record.	Apply data minimisation, access control and retention appropriate to the implementation environment.

13. Validation Criteria

Before adopting the framework in a live process, the implementation should be tested against fictional, historical-approved or otherwise suitable sample findings. Validation should focus on whether the process improves decision quality without changing accountability.

- Users can distinguish risk acceptance from remediation or closure.
- Every acceptance identifies a clear reason and an appropriate owner or approval path.
- The original finding, severity and technical conclusion remain unchanged.
- Accepted-but-unresolved findings remain visible and reviewable.
- Review dates or reassessment triggers can be identified and acted upon.
- Assessors are not required to make organisation-wide business-risk decisions.
- Any automation remains within the defined assistance boundary.
- The workflow is proportionate and does not create unnecessary administrative burden.

Success condition

The framework succeeds if it makes acceptance more informed, structured and reviewable while leaving the business-risk decision with the client and the technical finding intact.

14. Conclusion

Risk acceptance is most useful when it is treated as a governed lifecycle state rather than a terminal status. A clear record should show what remains unresolved, why the decision was made, who owns it, what controls or future work are relevant, and when the decision should be reconsidered.

This reference framework provides that structure without assuming a specific portal, consultancy workflow or technology stack. It can be adopted manually or implemented within existing security tooling, and optional automation can be added later without changing the core accountability model.

The next project artefact is the Retest Readiness and Evidence Framework, which applies the same platform-neutral design principle to preparation for remediation validation.

Appendix A - Example Risk Acceptance Record

The following example is fictional and illustrates the minimum record only. It is not a recommendation that the risk should be accepted.

Field	Example record
Finding ID / title	EXT-04 - Legacy TLS Protocols Supported
Original severity	Medium
Finding state	Risk Accepted - Vulnerability Remains Present
Reason for acceptance	A legacy integration currently depends on the affected protocol and is scheduled for replacement.
Risk owner	Head of Infrastructure
Compensating controls	External access restricted to approved source ranges; service monitored for anomalous access.
Planned remediation	Replace legacy integration and remove deprecated protocol support during migration.
Acceptance date	19 August 2026
Review date	19 November 2026
Reassessment triggers	Integration replacement date changes; service exposure increases; relevant exploit or threat changes; compensating control is removed.
Supporting reference	Change programme reference / client risk-register entry, if applicable.

Reminder

The acceptance record documents the client decision. It does not change the technical result of the original assessment and does not replace later remediation verification.